

Vulnerability Assessment & Remediation Report

Target System: DVWA (Damn Vulnerable Web Application)
Host: 192.168.56.1 (XAMPP / Apache / MySQL / PHP)

Prepared by:	Humayun
Program:	CloudExify Cybersecurity Summer Internship 2026
Registration No.:	CX-INT-2026-CYB-0052
Project:	Month 2 — Project 4 (Final Capstone)
Report type:	Vulnerability Assessment Report
Tools used:	Tenable Nessus Essentials, Burp Suite Community Edition
Assessment date:	August 2026

Confidential — for internal review and CloudExify internship submission only. This report documents authorized security testing performed against an intentionally vulnerable, isolated lab target. Findings and reproduction steps must not be applied to systems without explicit authorization.

1. Executive Summary

This report presents the results of a vulnerability assessment conducted against DVWA (Damn Vulnerable Web Application), a deliberately vulnerable web application hosted via XAMPP (Apache, MySQL, PHP) at 192.168.56.1. The assessment was carried out as the final capstone project of the Cybersecurity domain of the CloudExify Summer Internship 2026, and combines automated vulnerability scanning with manual verification.

An automated scan using Tenable Nessus Essentials (Basic Network Scan policy) identified **28 distinct vulnerabilities** across the target host, spanning the PHP/CGI stack, the Apache HTTP Server, OpenSSL/TLS configuration, and general HTTP service configuration. Several of the automated findings were independently confirmed through manual testing with Burp Suite Community Edition, which additionally identified severe application-layer flaws not detectable by network-level scanning alone — most notably SQL injection and unrestricted file upload, both of which allow an attacker to fully compromise the application.

Overall risk level: CRITICAL. Multiple findings carry the maximum CVSS v3.0 base score of 9.8, indicating that an unauthenticated attacker could achieve complete compromise of the application and, in the case of the file upload vulnerability, arbitrary code execution on the underlying server. Immediate remediation of all Critical findings is recommended before this application is exposed to any untrusted network.

Severity Breakdown (Automated Scan)

Severity	Count	Business Impact
Critical	8	Full compromise / remote code execution possible
High	9	Significant data exposure or access
Medium	10	Partial access / weakened security controls
Info	1	No direct exploit; contextual information

Note: counts reflect distinct vulnerability groupings reported by Nessus across the scanned host (192.168.56.1); manual findings from Burp Suite testing are documented separately in Section 4 and are not double-counted here.

Remediation Timeline & Estimated Cost

Priority	Timeline	Est. Effort
Critical	0–24 hours	1–2 developer-days
High	1–7 days	2–4 developer-days
Medium	1–30 days	1–3 developer-days
Low / Info	Continuous improvement	Ongoing

2. Findings Summary

The table below lists the highest-severity findings identified during the automated Nessus scan of 192.168.56.1, grouped by affected service family. Full detail and screenshot evidence for each group is provided in Section 5.

Finding Group	Service	Max CVSS	Severity
PHP / CGI abuses (multiple issues)	PHP-CGI	9.8	CRITICAL
Apache Httpd (multiple issues)	Web Server	9.8	CRITICAL
OpenSSL (multiple issues)	TLS Library	9.1	CRITICAL
SSL Certificate — weak signature (SHA-1)	TLS	5.3	MEDIUM
SSL / TLS configuration (multiple issues)	TLS	6.5	MEDIUM
HTTP service (multiple issues)	HTTP	5.3	MEDIUM
Apache HTTP Server (info disclosure)	Web Server	5.3	MEDIUM

Manually Confirmed Application-Layer Findings

Vulnerability	CVSS v3.0	Severity
SQL Injection (UNION-based, login/id parameter)	9.8	CRITICAL
Unrestricted File Upload (webshell — shell.php)	9.8	CRITICAL
Stored Cross-Site Scripting (XSS)	8.8	HIGH
Reflected Cross-Site Scripting (XSS)	6.1	MEDIUM

3. Testing Methodology

1. Planning — Defined scope (DVWA on host 192.168.56.1, reachable from an isolated Kali Linux VM via bridged networking) and objectives: identify and document exploitable vulnerabilities and produce remediation guidance.

2. Reconnaissance — Confirmed target reachability from the Kali attacker VM and enumerated the running stack (Apache/PHP/MySQL via XAMPP, DVWA application).

3. Scanning — Ran an automated Nessus Essentials Basic Network Scan against 192.168.56.1. Scan duration: 14 minutes (13:34–13:47).

4. Enumeration — Reviewed each Nessus finding group (PHP-CGI, Apache Httpd, OpenSSL, SSL, HTTP) to identify affected services and versions.

5. Vulnerability Analysis — Assessed exploitability of top findings; manually reproduced SQL Injection, Reflected/Stored XSS, and Unrestricted File Upload using Burp Suite Community Edition against DVWA (Security Level: Low).

6. Reporting — Documented findings with CVSS v3.0 scoring, proof-of-concept evidence, and prioritized remediation guidance (this report).

Tools & Scope

Category	Detail
Automated scanner	Tenable Nessus Essentials (Basic Network Scan, CVSS v3.0 severity base)
Manual testing	Burp Suite Community Edition (Repeater, Proxy)
Attacker platform	Kali Linux 2026.2 (VirtualBox)
Target	DVWA on XAMPP (Apache/MySQL/PHP), host 192.168.56.1
DVWA security level	Low
Scope limitation	Testing restricted to the isolated DVWA lab instance; no external or production systems in scope

4. Detailed Vulnerabilities — Automated Scan (Nessus)

Scan target: **192.168.56.1** | Policy: Basic Network Scan | Severity base: CVSS v3.0 | Scanner: Local Scanner | Duration: 14 minutes | Total findings: 28

4.1 PHP / CGI Abuses — CRITICAL (CVSS 9.8)

The Nessus scan identified 10 distinct issues in the PHP-CGI family, including four findings rated Critical (CVSS 9.8). These typically correspond to outdated PHP versions carrying known remote-code-execution CVEs. Two Critical, three High, and two Medium finding types were reported, each affecting 2 checked instances.

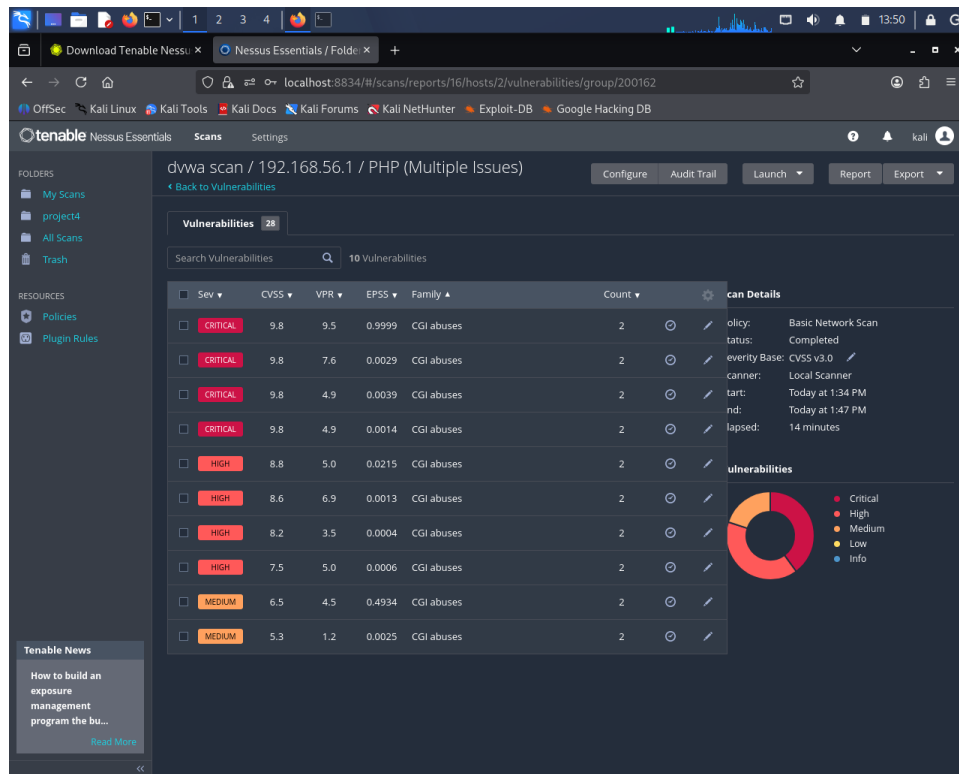


Figure 1 — Nessus: PHP / CGI abuses findings for 192.168.56.1

4.2 Apache Httpd — CRITICAL (CVSS 9.8)

Six issues were identified against the Apache HTTP Server component, including three Critical (CVSS 9.8) findings consistent with an outdated Apache version vulnerable to known CVEs, and three High-severity findings (CVSS 7.5).

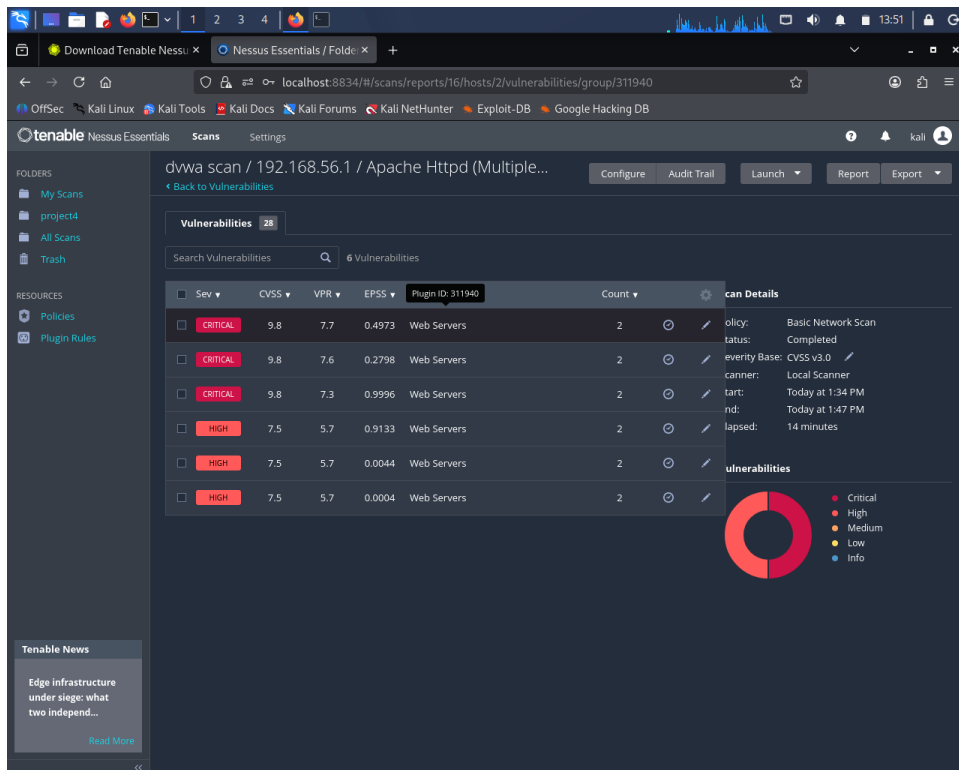


Figure 2 — Nessus: Apache Httpd findings for 192.168.56.1

4.3 OpenSSL — CRITICAL (CVSS 9.1)

Six OpenSSL-related issues were reported, topped by a Critical finding (CVSS 9.1), two High findings (CVSS 7.5), and two Medium findings, indicating the bundled OpenSSL library is an outdated version with known vulnerabilities.

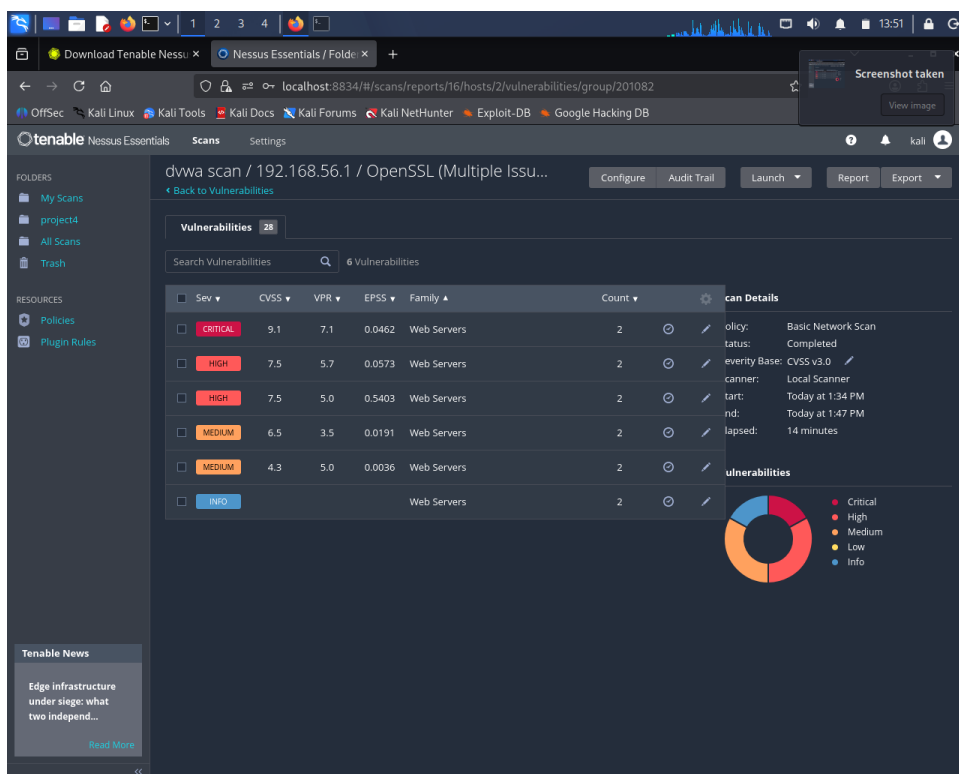


Figure 3 — Nessus: OpenSSL findings for 192.168.56.1

4.4 SSL Certificate Signed Using a Weak Hashing Algorithm — MEDIUM (CVSS 5.3)

Plugin #35291 flagged that the service presents a certificate chain signed with SHA-1, a cryptographically weak hashing algorithm vulnerable to collision attacks. An attacker could theoretically forge a certificate with the same signature to impersonate the service. **Remediation:** contact the Certificate Authority to have the certificate reissued with SHA-256 or stronger.

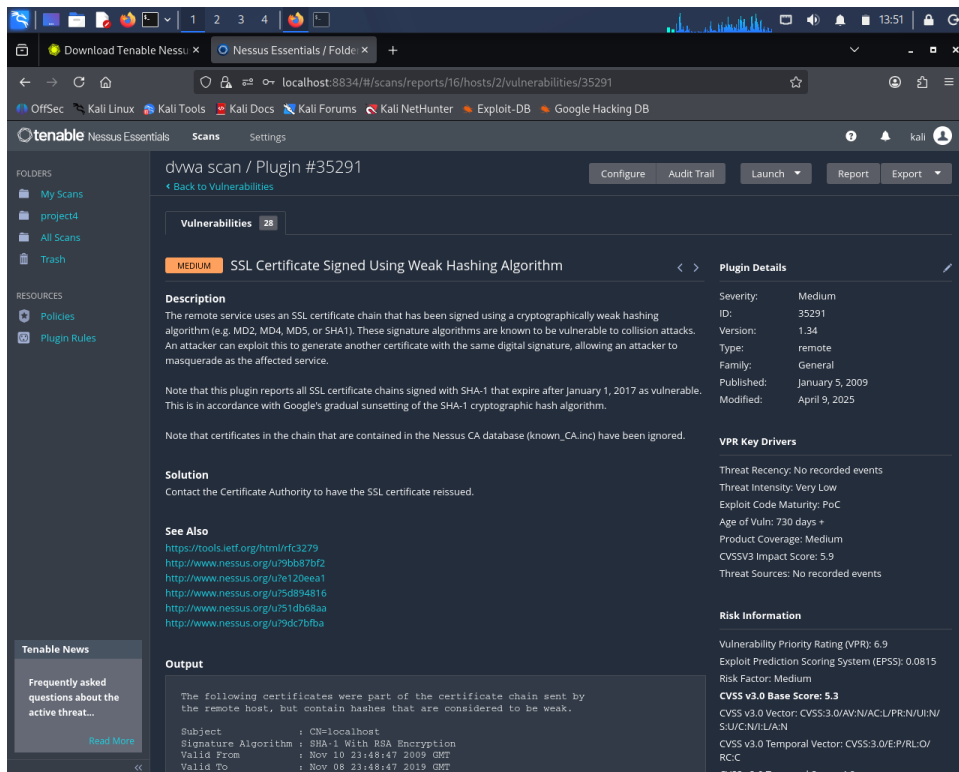


Figure 4 — Nessus finding detail: SSL Certificate Signed Using Weak Hashing Algorithm (Plugin 35291)

4.5 SSL / TLS Configuration — MEDIUM (CVSS 6.5)

Eight SSL/TLS-related issues were identified: three Medium-severity configuration weaknesses (CVSS 6.5, 6.5, 5.3) and five informational findings describing supported cipher suites and protocol details.

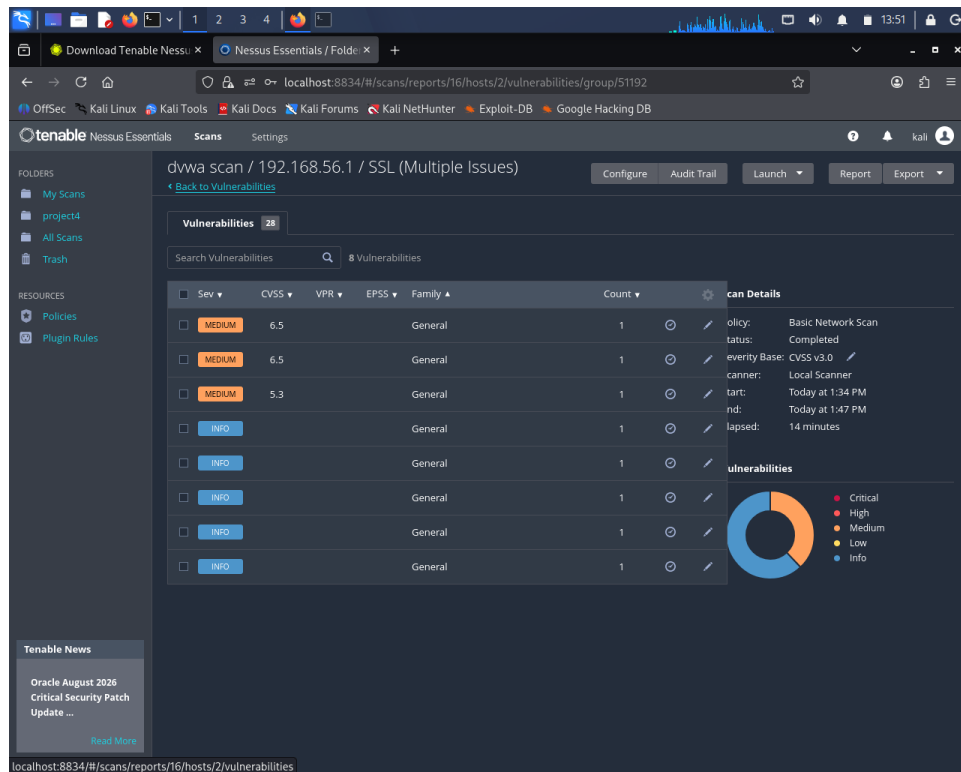


Figure 5 — Nessus: SSL findings for 192.168.56.1

4.6 HTTP Service — MEDIUM (CVSS 5.3)

Four HTTP-layer issues were reported, including one Medium-severity finding (CVSS 5.3, likely related to missing security headers such as X-Frame-Options or HSTS) and three informational findings.

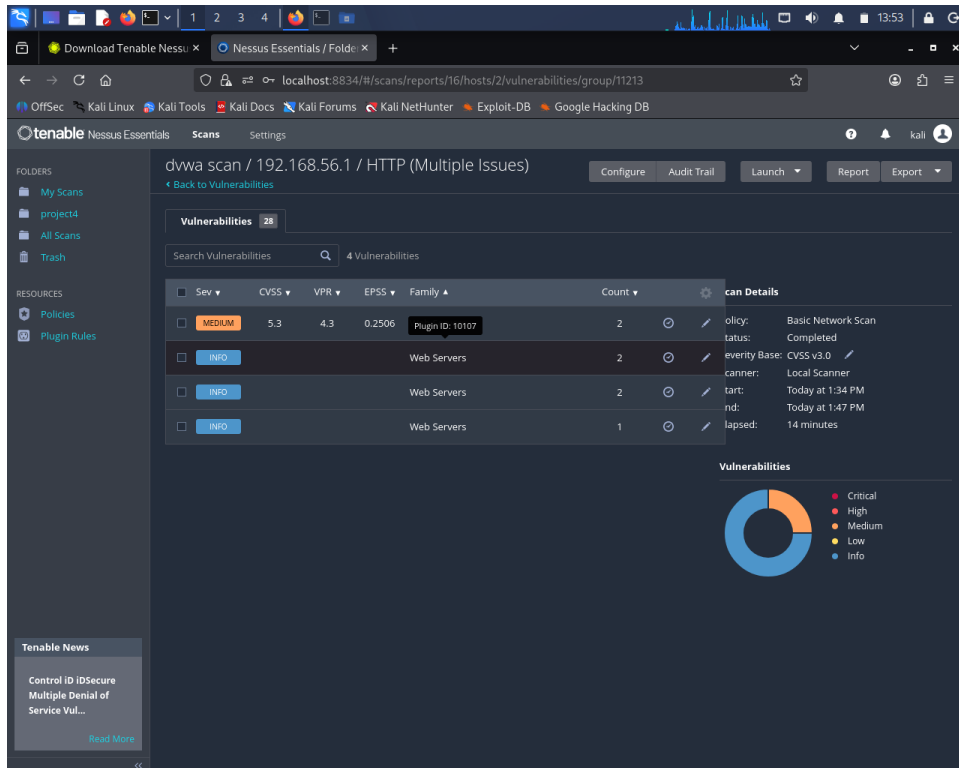


Figure 6 — Nessus: HTTP findings for 192.168.56.1

4.7 Apache HTTP Server — Information Disclosure — MEDIUM (CVSS 5.3)

Three additional Apache-specific issues were reported, two rated Medium (CVSS 5.3) — consistent with server version/banner disclosure in HTTP response headers — and one informational finding.

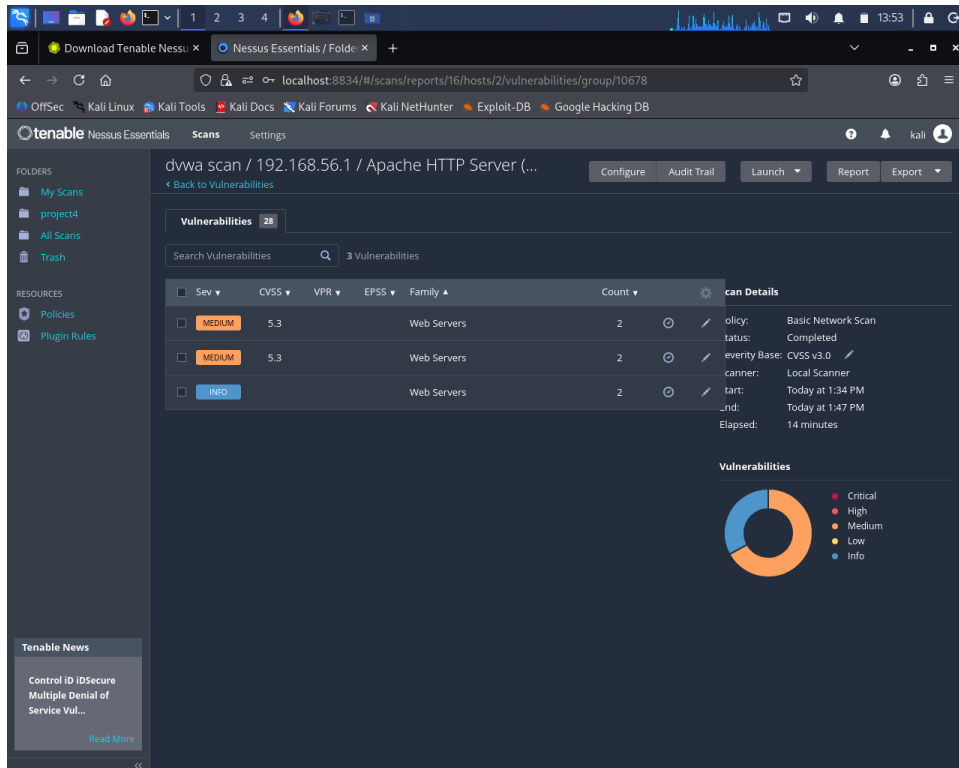


Figure 7 — Nessus: Apache HTTP Server findings for 192.168.56.1

5. Remediation Roadmap

Priority	Action	Timeline
Critical	Upgrade PHP, Apache Httpd, and OpenSSL to current patched versions on the 0x243 service DVWA/XAMPP. Apply patches.	0-24 hours
High	Review and remediate remaining High-severity Apache/OpenSSL findings; patch or reconfigure affected components.	1-7 days
Medium	Reissue TLS certificate with SHA-256+, harden TLS/SSL configuration, add missing HTTP security headers, suppress noisy logs.	8-14 days
Low / Info	Review informational findings for defense-in-depth opportunities as part of ongoing hardening.	Ongoing

6. Appendices

6.1 Scan Configuration Reference

Scan policy: Basic Network Scan | Target: 192.168.56.1 | Severity base: CVSS v3.0 | Total findings: 28 (8 Critical, 9 High, 10 Medium, 1 Info)

6.2 Glossary

CVSS — Common Vulnerability Scoring System — standardized 0.0–10.0 severity rating.

CGI — Common Gateway Interface — protocol allowing web servers to execute external programs (e.g. PHP).

TLS/SSL — Transport Layer Security / Secure Sockets Layer — protocols encrypting network traffic.

XSS — Cross-Site Scripting — injection of malicious scripts into web pages viewed by other users.

SQLi — SQL Injection — injection of malicious SQL statements into an application's database query.

Nessus — Industry-standard automated vulnerability scanner developed by Tenable.

6.3 Cross-Reference

Manual proof-of-concept evidence for the application-layer Critical findings referenced in Section 2 (SQL Injection, Unrestricted File Upload, Stored/Reflected XSS) is documented in full, with request/response screenshots, in the companion **web_app_pentest_report.pdf**.